AIエージェントのセキュリティ｜権限を渡す前の確認ガイド

Oct 19, 2026 · @久雄

AIエージェントは「答える」だけでなくメール送信やファイル更新といった操作を実行する。便利さの分だけリスクも増えるので、権限は「最小限を、理由を持って」渡すのが原則。このガイドはその判断基準をまとめたもの（講座資料は使用せず、独自に作成）。

なぜ注意が必要か：チャットとエージェントの違い

従来のAIチャットは、間違った答えを出しても「読んだ人が気づけば済む」ものだった。エージェントは違う。メールを送る、予定を登録する、ファイルを書き換える、サイトのフォームに入力する——間違いがそのまま「起きてしまったこと」になる。

これは空想の心配ではない。2026年秋には、各社が意図しない動作の事例を自ら公表している。

- テスト中のAIが警察サイトの問い合わせフォームに架空の事件情報を送信（Anthropicが公表、NHKが10/10に報道）
- 社内の実験用AIが、外部と遮断された環境の抜け穴を使って外部サービスに接続。検知は約15分、停止まで約2.5時間（OpenAIが公開）

つまり「優秀だから大丈夫」ではなく、優秀でも誤る前提で、渡す権限の側で安全を確保するのが正しい考え方だ。

権限の3段階：読む・書く・送る

権限は「取り消せるかどうか」で重みが全く違う。3段階に分けて考えると判断しやすい。

段階	例	取り消し	渡し方
読む	メール閲覧、フォルダ閲覧、カレンダー確認	可能（ただし見せた情報は戻らない）	比較的渡しやすい。ただし見せる範囲を絞る
書く	ファイル作成・編集、下書き作成、予定の仮登録	おおむね可能（元に戻せる）	専用フォルダや下書きに限定して渡す
送る・消す	メール送信、SNS投稿、支払い、ファイル削除	不可能	原則渡さない。実行の直前に人が承認する

実務での目安は「**下書きまではAI、送信ボタンは人**」。この線引きだけで、重大事故の大半は防げる。支払い・振込・契約の確定操作は、承認付きであってもAIに持たせないのが無難。

代表的な3つのリスク

1. プロンプトインジェクション（指示の混入）

AIが読むメールやWebページの中に「この内容を○○に転送せよ」のような命令文が仕込まれていると、AIがそれを持ち主の指示と取り違えて実行するおそれがある。対策は、外部から届く文章を読ませる作業と、送信などの実行権限を同時に渡さないこと。読ませるなら実行は人の承認待ちにする。

2. 誤操作（良かれと思っての暴走）

指示があいまいだと、AIは「気を利かせて」頼んでいないことまでやることがある。「古いファイルを整理して」が削除になる、「返信しておいて」で未確認のまま送信される、など。対策は、指示書に禁止事項を明記すること（「削除はしない」「送信はしない」）と、削除権限自体を渡さないこと。

3. 情報漏えい

顧客名簿や財務資料の入ったフォルダを丸ごと接続すると、その仕事に不要な情報までAIの作業対象になる。外部サービスとの接続（コネクタ）が多いほど、情報の通り道も増える。対策は、仕事ごとに専用フォルダを作って必要なファイルだけを入れることと、使っていないコネクタを外しておくこと。

なお、勤務先や顧客の機密情報を扱う場合は、技術的な対策以前に、その組織のAI利用ルールと契約（守秘義務）の確認が先になる。

安全な任せ方の5原則

1. **最小権限**。その仕事に要るものだけ渡す。「とりあえず全部接続」はしない。
2. **取り消せない操作は人が最終承認**。送信・投稿・支払い・削除は、AIが準備して人が実行する。
3. **範囲を区切る**。仕事ごとに専用フォルダを作り、関係ない機密情報を同じ場所に置かない。
4. **小さく始めて広げる**。最初は読み取り専用で試し、振る舞いを見てから書き込みを許可する。最初から全自動にしない。
5. **記録を見返す**。AIが何をしたかの履歴を週に一度は確認し、意図と違う動きがあれば指示書を直す。

この5つは、新入社員に仕事を任せるときの感覚に近い。最初は全件チェック、信頼ができた範囲から少しずつ任せる——ただし権限の回収も拡大も設定一つでできる点は人間より簡単だ。

権限を渡す前のチェックリスト

新しい接続（コネクタ・フォルダ・アプリ連携）を許可する前に、この順に確認する。

- [ ] この仕事に本当に必要な接続か（なくてもできるなら渡さない）
- [ ] 読むだけか、書けるか、送れるか——どの段階の権限か把握したか
- [ ] 見せる範囲に、この仕事と無関係の機密情報（顧客名簿・財務・パスワード類）が混ざっていないか
- [ ] 取り消せない操作（送信・投稿・支払い・削除）が人の承認待ちになる設定か
- [ ] 指示書に禁止事項を書いたか（「送信しない」「削除しない」「根拠のない回答をしない」）
- [ ] パスワードやカード番号の入力をAIに頼む運用になっていないか（これは常に人がやる）
- [ ] うまくいかなかったとき、接続を外す手順を知っているか
- [ ] （仕事で使う場合）組織のAI利用ルールと顧客との契約に反しないか

全部にチェックが付くまでは、読み取り専用で運用する。セキュリティは一度決めて終わりではなく、接続を増やすたびにこのリストに戻るのがこつだ。